Cuidarte+

Informe de seguridad y calidad en el desarrollo de software

ISY1102 - Seguridad y calidad en el desarrollo de software

Carrera: Ingeniería en Informática

Sección: XX

Integrantes

Cristian Cerda

Gonzalo Berríos

Docente

Cristian Medina

Fecha de entrega: 24 de septiembre de 2026

INDICE

INDICE 2
1. Introducción 3
1.1 Contexto del sistema evaluado 3
1.2 Objetivos del plan de pruebas 3
1.3 Alcance 4
1.4 Estructura del informe 4
2. Criterios de calidad, seguridad y cumplimiento normativo 4
2.1 Calidad de software (ISO/IEC 25010) 5
2.2 Seguridad 5
2.3 Normativas y cumplimiento legal 5
3. Tipos de pruebas y su justificación 6
4. Estrategia de pruebas y justificación 7
4.1 Enfoque y etapas 7
4.2 Priorización de las pruebas 7
4.3 Criterios de entrada y salida 7
4.4 Criterios de aceptación transversales 8
4.5 Cronograma de ejecución 8
5. Recursos necesarios 9
5.1 Recursos humanos 9
5.2 Recursos técnicos y herramientas 9
5.3 Entorno de prueba 10
6. Diseño de casos de prueba 10
Anexos 23
Anexo A. Matriz de trazabilidad ERS - casos de prueba 23
Anexo B. Catálogo de hallazgos de seguridad 25
Anexo C. Evidencia de ejecución automatizada 27

1. Introducción

1.1 Contexto del sistema evaluado

Cuidarte+ es una plataforma web médica multicapa para centros de salud: gestión de pacientes, exámenes médicos, documentos clínicos y auditoría. El software se compone de una SPA React (v19.1.1) con Material UI y Tailwind servida por Nginx, una API RESTful Node.js/Express (v4.19.2) con validaciones yup y JWT, y una base de datos PostgreSQL con documentos clínicos almacenados en BYTEA. El despliegue se realiza con Docker Compose (backend :4444, frontend :3333, Postgres :15442).

Los datos manejados (RUT, fichas clínicas, diagnósticos) son sensibles según la Ley N° 19.628 y la Ley N° 20.584: confidencialidad, integridad y disponibilidad son críticas. Por esta razón es necesario contar con un plan de pruebas que verifique de forma objetiva y reproducible que el software cumple el ERS v1.1, los criterios de calidad ISO/IEC 25010, OWASP Top 10 y la legislación chilena aplicable, antes de cualquier paso a producción.

El propósito de este informe es definir la estrategia de aseguramiento de calidad (SQA) y validación de seguridad que permita asegurar: (1) el cumplimiento funcional de cada RF del ERS contra los endpoints reales; (2) los atributos no funcionales (latencia <300 ms, 200 usuarios concurrentes, carga inicial <2 s, uptime 99.5%, WCAG 2.1 AA); (3) la seguridad de autenticación, RBAC y controles OWASP sin fuga de información clínica; y (4) la conformidad legal con las leyes 19.628 y 20.584 y una auditoría trazable (RF-5.1).

1.2 Objetivos del plan de pruebas

Objetivo general: verificar, de forma objetiva y reproducible, que Cuidarte+ cumple los requerimientos del ERS v1.1 y los marcos de calidad, seguridad y legalidad aplicables, antes de autorizar su paso a producción.

Objetivos específicos:

- Verificar el cumplimiento funcional de cada requerimiento funcional (RF-1.1 a RF-5.1) contra los endpoints reales de la API.
- Medir los atributos no funcionales comprometidos: latencia inferior a 300 ms, 200 usuarios concurrentes, carga inicial de la SPA bajo 2 s, disponibilidad de 99,5% y accesibilidad WCAG 2.1 AA.
- Validar los controles de seguridad de autenticación, autorización por roles (RBAC) y los riesgos de OWASP Top 10 (2021), sin fuga de información clínica.
- Comprobar la conformidad legal con la Ley N° 19.628 y la Ley N° 20.584, incluida la trazabilidad de la auditoría exigida por RF-5.1.

• Entregar evidencia trazable que permita decidir, con fundamento técnico, si el producto se certifica o se rechaza.

1.3 Alcance

Dentro del alcance: la API Express completa (/autenticacion, /usuarios, /pacientes, /examenes, /documentos, /auditoria, /roles y /docs), la SPA React, el esquema PostgreSQL y el almacenamiento de documentos clínicos. Fuera del alcance: la infraestructura del centro de datos, los componentes de terceros no auditados y la modificación del código fuente, ya que este encargo es de análisis y prueba, no de corrección.

Glosario de siglas empleadas: ERS (especificación de requerimientos de software), RF (requerimiento funcional), NFR (requerimiento no funcional), RB (regla de negocio), RBAC (control de acceso basado en roles), SAST y DAST (análisis estático y dinámico de seguridad), UAT (pruebas de aceptación de usuario), JWT (token web JSON), SPA (aplicación de página única) y soft delete (borrado lógico).

1.4 Estructura del informe

El informe se organiza en seis secciones y tres anexos:

• Sección 2 — Criterios de calidad, seguridad y cumplimiento normativo que el software debe satisfacer.
• Sección 3 — Tipos de prueba seleccionados y la justificación de cada uno.
• Sección 4 — Estrategia de pruebas, priorización, criterios de entrada y salida, criterios de aceptación transversales y cronograma.
• Sección 5 — Recursos humanos, técnicos y de entorno necesarios para ejecutar el plan.
• Sección 6 — Diseño de los 19 casos de prueba (CP-01 a CP-19) sobre los endpoints y el esquema reales.
• Anexos A, B y C — Matriz de trazabilidad, catálogo de hallazgos y evidencia de la ejecución automatizada.

2. Criterios de calidad, seguridad y cumplimiento normativo

Los criterios se derivan del ERS v1.1 (especificación de requerimientos de software del proyecto), de ISO/IEC 25010 para atributos de calidad, de OWASP Top 10 (2021) para seguridad y de la legislación chilena aplicable al software médico. Estos criterios definen el estándar que el software debe cumplir y son la base de los casos de prueba de la sección 6.

2.1 Calidad de software (ISO/IEC 25010)

• Usabilidad (NFR-USAB): WCAG 2.1 AA; tipografía ≥12 px; contraste ≥4.5:1; etiquetas WAI-ARIA; targets ≥48×48 px; navegación 100% por teclado; foco en adultos mayores (NFR-USAB-1, NFR-USAB-4).

• Rendimiento (NFR-PERF): API CRUD <300 ms (NFR-PERF-1); carga inicial de SPA <2 s en red móvil (NFR-PERF-2); 200 usuarios concurrentes (NFR-PERF-3); subida/descarga de adjuntos ≤10 s (RF-4).

• Disponibilidad (NFR-DIS): uptime 99.5% mensual (NFR-DIS-1); ventanas de mantenimiento con respaldo y rollback (NFR-DIS-2).

• Estabilidad y confiabilidad: cero caídas bajo carga (NFR-PERF-3), pool de PostgreSQL sin agotamiento, respaldos restaurables (NFR-SEG-7).

• Mantenibilidad: desacoplamiento React ↔ Express ↔ PostgreSQL; OpenAPI vigente en /docs y /openapi.json.

2.2 Seguridad

• Protección de datos en tránsito (NFR-SEG-1): TLS 1.2+ obligatorio, redirect HTTP→HTTPS, HSTS y cabeceras Content-Security-Policy, X-Content-Type-Options y X-Frame-Options.

• Protección de datos en reposo (NFR-SEG-3): cifrado de documentos_examen.documento y de los backups.

• Autenticación (NFR-SEG-2, RF-1.1, NFR-SEG-9): bcrypt cost ≥12; access JWT ≤15 min + refresh rotativo en cookie HttpOnly; Secure; SameSite=Strict; política ≥12 caracteres (4 clases); rate limit de login.

• Control de acceso (NFR-SEG-4): middlewares en backend para admin, medico y paciente; reglas RB-1/RB-2/RB-3; falla por denegación (401/403).

• Manejo de errores e integridad (NFR-SEG-5, criterio 'sin stack trace'): SQLi con consultas parametrizadas pg ($1); XSS con escape React + CSP; CSRF con SameSite + token; respuestas 500 genéricas sin err.message de PostgreSQL.

• Auditoría (RF-5.1, NFR-SEG-7): tabla auditoria con usuario_id, acción, recurso_id, ip_origen y fecha_hora UTC; escritura atómica con la mutación; REVOKE UPDATE, DELETE; backups diarios cifrados con prueba de restauración.

2.3 Normativas y cumplimiento legal

• Ley N° 19.628: RUT, nombres, correos y diagnósticos son datos sensibles; principio de finalidad y confidencialidad; solo Médico/Administrador procesa.

• Ley N° 20.584: derecho del paciente a sus propios exámenes (RF-4.1/4.2); reserva clínica absoluta frente a terceros (RB-1); edición reservada al profesional tratante (RF-3.1, RB-3).

• RF-5.1: logs inmutables con usuario, acción, recurso, timestamp UTC e IP para peritaje; retención ≥12 meses.

• Estándares técnicos: ISO/IEC 25010, OWASP Top 10 (2021), WCAG 2.1 AA y OpenAPI como contrato de la API.

Matriz RBAC esperada (oracle de las pruebas): la tabla de roles por endpoint del ERS (admin/medico/paciente/sin token) es la referencia obligatoria de los casos CP-06, CP-07, CP-18 y CP-19. Celdas denegadas deben responder 403 {"error":"No autorizado"} y, sin token, 401.

3. Tipos de pruebas y su justificación

La selección de tipos de prueba responde a la naturaleza del software evaluado: una aplicación clínica que maneja datos sensibles bajo requerimientos funcionales, no funcionales y legales. Cada tipo se incorpora porque cubre una familia de requerimientos que ningún otro tipo puede verificar, y se indica el caso de prueba que lo materializa.

Tipo de prueba	Propósito y justificación	Requerimientos	Casos
Funcionales	Verifican que cada caso de uso produzca el resultado especificado. Son el primer filtro: si el login o el registro de un examen no funcionan, ningún atributo de calidad es relevante.	RF-1.1 a RF-5.1	CP-01, CP-04, CP-05
De integración	Comprueban el flujo completo SPA React - API Express - PostgreSQL. La mayoría de los defectos de esta arquitectura aparece en los contratos entre capas, no dentro de ellas.	ERS §2.1 y §4	CP-04, CP-05
De seguridad (SAST y DAST)	Detectan inyección SQL, XSS, CSRF, elusión de JWT, cabeceras ausentes y fallas de control de acceso. Son obligatorias porque el sistema trata datos sensibles regidos por ley.	NFR-SEG-1 a NFR-SEG-9	CP-10, CP-11, CP-12, CP-18, CP-19
De control de acceso (RBAC)	Validan que cada rol acceda solo a lo que le corresponde. Es el control que protege la reserva de la ficha clínica exigida por la Ley N° 20.584.	NFR-SEG-4, RB-1/2/3	CP-06, CP-07, CP-18
De rendimiento y carga	Miden latencia y estabilidad bajo concurrencia. Un sistema clínico lento en consulta retrasa la atención, por lo que el rendimiento es un requisito de servicio, no un lujo.	NFR-PERF-1/2/3	CP-13, CP-14
De usabilidad y accesibilidad	Verifican legibilidad, contraste, etiquetado ARIA y navegación por teclado. El público objetivo incluye adultos mayores, lo que convierte la accesibilidad en un criterio de aceptación.	NFR-USAB-1/4, WCAG 2.1 AA	CP-15
De compatibilidad	Confirman el funcionamiento en los navegadores y dispositivos declarados. Los pacientes acceden desde equipos heterogéneos que la institución no controla.	NFR-COMPAT-1/2	CP-16
De integridad y auditoría	Comprueban el borrado lógico y la bitácora inmutable de acciones críticas. La ficha clínica debe conservarse y toda acción debe ser atribuible para efectos de peritaje.	RF-3.3, RF-5.1	CP-08, CP-09
De disponibilidad y recuperación	Validan el nivel de servicio comprometido y la restauración de respaldos. La indisponibilidad de una plataforma clínica tiene impacto asistencial directo.	NFR-DIS-1/2, NFR-SEG-7	CP-17

Tabla 3.1. Tipos de prueba seleccionados, su justificación y los casos que los materializan.

Las pruebas funcionales, de integración y de control de acceso se consideran bloqueantes: un fallo en cualquiera de ellas impide la certificación. Las de rendimiento, usabilidad, compatibilidad y disponibilidad admiten un plan de mitigación acordado, siempre que queden documentadas con su medición.

4. Estrategia de pruebas y justificación

4.1 Enfoque y etapas

El enfoque es mixto: automatizado para la API (Postman/Newman, JMeter, ZAP) y manual para flujos de UI, accesibilidad y UAT. Las etapas del proceso son:

- Etapa 1 — Unitarias/integración (Jest + Supertest, a incorporar; hoy el repositorio no tiene tests): validaría validate.js, requireRole y rutas JWT. Prioridad P1.
- Etapa 2 — Funcionales/sistema (Postman/Newman + UI manual): login, CRUD de usuarios/pacientes/exámenes/documentos, RBAC y soft delete. Prioridad P1.
- Etapa 3 — No funcionales (JMeter para carga y OWASP ZAP para DAST): 200 usuarios, SQLi/XSS, cabeceras TLS y latencia vs delayMiddleware. Prioridades P1/P2.
- Etapa 4 — UAT/accesibilidad (Axe DevTools + panel de 5 adultos mayores): WCAG 2.1 AA, legibilidad, teclado y táctil. Prioridad P2.

Herramientas que se utilizarán (detalle en la sección 5): Postman/Newman, Apache JMeter, OWASP ZAP, Axe/Lighthouse, Jest+Supertest, psql/pgAdmin, curl/SSL Labs y Docker Compose.

4.2 Priorización de las pruebas

La priorización sigue el riesgo clínico y legal: primero lo que expone datos de pacientes o permite tomar control del sistema, después lo que degrada el servicio y, por último, lo que afecta la experiencia en escenarios acotados.

- P1 – Crítica: login/sesión, RBAC sin fuga, exámenes+adjuntos, auditoría, SQLi/XSS, auth de endpoints mutantes (CP-01, CP-02, CP-04, CP-06, CP-07, CP-08, CP-09, CP-10, CP-11, CP-12, CP-18, CP-19).
- P2 – Alta: rendimiento <300 ms/200 usuarios, accesibilidad, registro de pacientes, contraseñas, carga <2 s y disponibilidad (CP-03, CP-05, CP-13, CP-14, CP-15, CP-17).
- P3 – Media: compatibilidad de navegadores/dispositivos (CP-16).

4.3 Criterios de entrada y salida

Criterios de entrada (condiciones sin las cuales no se inicia la ejecución):

- Código fuente extraído y desplegado en QA/Staging (Docker) sin modificar el software.

- PostgreSQL inicializado con init.sql + dump-cuidarteplus.sql (datos 100% sintéticos).
- ERS v1.1 aprobado y matriz de trazabilidad lista (28 IDs).
- OpenAPI vigente en /docs y colección Postman exportada con los endpoints reales.

Criterios de salida:

- 100% de casos P1 y P2 ejecutados con estado APROBADO/RECHAZADO justificado.
- Cero vulnerabilidades críticas/altas sin registrar en el informe de hallazgos.
- Latencia ≤300 ms en el 95% de peticiones sin delay artificial; endpoints con delay(5000) documentados como incumplimiento de NFR-PERF-1.
- Accesibilidad ≥90% sin violaciones críticas WCAG 2.1 AA y evidencia completa según protocolo de evidencia.

4.4 Criterios de aceptación transversales

Los siguientes criterios de aceptación son transversales: se aplican a todos los casos de prueba y una prueba solo se considera aprobada si cumple la totalidad de los criterios aplicables a su tipo (funcional, no funcional y reglas de negocio):

- Autorización: ningún endpoint entrega datos sin JWT válido conforme a la matriz RBAC del ERS (RB-1/2/3); denegaciones en backend con 401/403.
- HTTP estandarizado con JSON predecible: 200 OK · 201 creado · 400 {error, glosa, detalles} · 401 token · 403 No autorizado · 404 No encontrado · 500 sin exponer err.message de PostgreSQL.
- Soft delete obligatorio: prohibido DELETE FROM sobre examen_medico, pacientes, usuarios y documentos_examen (RF-3.3), con confirmación modal previa en UI.
- Latencia: consultas/actualizaciones <300 ms en el 95%; adjuntos ≤10 s; delayMiddleware solo si NODE_ENV=development.
- Auditoría incondicional y atómica: toda mutación inserta log (con IP y recurso) en la misma transacción, antes del 200/201.
- Trazabilidad de errores: todo 500 registra ID correlacionable en el log de servidor sin filtrar detalles al cliente.
- Reglas de negocio y legal: reserva clínica (Ley 20.584), confidencialidad de datos (Ley 19.628) y soft delete con modal (RF-3.3) deben cumplirse en todos los flujos sensibles.

4.5 Cronograma de ejecución

La ejecución se planifica en cuatro semanas, encadenando las etapas de modo que cada una entregue la línea base que la siguiente necesita. Las pruebas de seguridad se ubican después de las funcionales porque requieren un sistema estable; la aceptación de usuario se deja al final para evaluar la versión ya corregida en lo bloqueante.

Semana	Etapa	Actividades	Casos	Entregable
1	Preparación y pruebas unitarias/de integración	Despliegue del entorno QA en Docker, carga del dump sintético, incorporación de Jest y Supertest, y exportación de la colección Postman.	Base técnica	Entorno QA operativo y colección versionada
2	Pruebas funcionales y de integración	Ejecución de los casos de autenticación, CRUD de usuarios, pacientes, exámenes y documentos, más el control de acceso por rol.	CP-01 a CP-09	Matriz de resultados funcionales
3	Pruebas de seguridad y de rendimiento	Análisis dinámico con OWASP ZAP, verificación de cabeceras y TLS, pruebas de carga con JMeter y medición de latencia A/B.	CP-10 a CP-14, CP-18, CP-19	Informe de hallazgos y de rendimiento
4	Aceptación, compatibilidad y cierre	Panel de usabilidad con cinco adultos mayores, matriz de compatibilidad, verificación de disponibilidad y consolidación del informe final.	CP-15 a CP-17	Informe final y veredicto de certificación

Tabla 4.1. Cronograma de ejecución del plan de pruebas.

5. Recursos necesarios

La ejecución del plan requiere recursos humanos con competencias diferenciadas, recursos técnicos de software y hardware, y un entorno de prueba aislado. A continuación se detalla cada categoría junto con el fundamento de su necesidad.

5.1 Recursos humanos

Rol	Responsabilidad	Dedicación
QA Lead	Diseña y mantiene el plan, coordina la ejecución, consolida la evidencia y emite el veredicto de certificación.	4 semanas, jornada completa
Especialista en ciberseguridad (pentester)	Ejecuta el análisis estático y dinámico, clasifica los hallazgos según OWASP y valida las reglas de control de acceso.	2 semanas (semanas 2 y 3)
Dos desarrolladores de soporte	Resuelven dudas sobre el código, reproducen defectos y preparan las correcciones. La corrección en sí queda fuera del alcance de este informe.	Media jornada, a demanda
Panel de cinco personas adultas mayores	Ejecutan las pruebas de aceptación de usuario. Su participación es indispensable porque son el perfil de usuario declarado en NFR-USAB.	Una sesión de 2 horas (semana 4)

Tabla 5.1. Roles involucrados en la ejecución del plan.

5.2 Recursos técnicos y herramientas

Herramientas tecnológicas y fundamento de su uso en la ejecución de las pruebas:

- Postman / Newman — pruebas funcionales e de integración: suites HTTP con Authorization: Bearer y validación JSON en CI (ejecutable con npm test).
- Apache JMeter 5.6 — carga/estrés: 200 hilos, ramp-up 10 s y Aggregate Report para NFR-PERF-1/3.

• OWASP ZAP — DAST: spider + active scan de XSS, SQLi, cabeceras y cookies (NFR-SEG-5).
• Axe DevTools / Lighthouse — accesibilidad y carga de SPA: WCAG 2.1 AA y Lighthouse <2 s (NFR-USAB, NFR-PERF-2).
• Jest + Supertest — unitarias/integración (a incorporar; hoy 0 tests en el repo).
• psql / pgAdmin — verificación de BD: soft delete, contenido de auditoría y hashes de contraseñas.
• curl / SSL Labs — TLS y cabeceras: curl -I y enumeración de protocolos (NFR-SEG-1).
• Docker Compose — ambiente QA: réplica aislada del ZIP sin tocar el código fuente.

Equipamiento y software base:

• Estación de trabajo Intel i7 con 16 GB de memoria para generar la carga de JMeter sin que el generador se transforme en el cuello de botella de la medición.
• Equipos de escritorio, tablets y teléfonos para la matriz de compatibilidad y las pruebas táctiles de accesibilidad.
• Navegadores Chrome, Firefox, Safari y Edge, en sus dos últimas versiones estables, según NFR-COMPAT-1.
• Node.js 18 o superior, Docker Desktop y un certificado TLS de prueba para verificar NFR-SEG-1.

5.3 Entorno de prueba

Las pruebas se ejecutan en un entorno de QA aislado, levantado con docker-compose.yml (backend en el puerto 4444, frontend en el 3333 y PostgreSQL en el 15442), poblado exclusivamente con los datos sintéticos del dump del proyecto y sin conexión a la red operativa ni a datos reales de pacientes, en cumplimiento de la Ley N° 19.628. El código de la aplicación no se modifica en ningún momento: el entorno replica el software tal como fue entregado, de modo que la evidencia obtenida sea atribuible al producto evaluado.

Se definen tres ambientes: desarrollo (uso de las personas desarrolladoras, fuera del alcance de este plan), QA (donde se ejecuta la totalidad de los casos aquí diseñados) y preproducción (réplica de producción, reservada para la reejecución de regresión una vez corregidos los hallazgos bloqueantes).

6. Diseño de casos de prueba

Se diseñan 19 casos de prueba, muy por encima del mínimo de cinco exigido, con el fin de cubrir la totalidad de los requerimientos del ERS. Cada ficha detalla el identificador del caso, su nombre, el requerimiento asociado con su código del ERS, el tipo de prueba, la descripción del objetivo, las

precondiciones, los pasos, el resultado esperado, los criterios de aceptación y los datos de entrada. Los casos se ejecutan contra el entorno de QA en Docker (http://localhost:4444).

ID	NOMBRE	REQUERIMIENTO
CP-01	Autenticación y emisión de JWT	RF-1.1, NFR-SEG-2, NFR-SEG-9
DESCRIPCIÓN		
Validar la autenticación con credenciales válidas en /autenticacion/login y la emisión de un token JWT firmado, además del rechazo de credenciales inválidas.		
PRECONDICIONES		
Usuario existe en la tabla usuarios (dump dump-cuidarteplus.sql); API y BD operativas en el entorno QA Docker (backend :4444).		
PASOS		
1) Login vía UI (/login) o Postman. 2) Verificar respuesta {"token": "..."}. 3) Decodificar el payload JWT. 4) Usar el token en GET /examenes. 5) Login con clave incorrecta. 6) Revisar que el log del servidor no contenga la contraseña.		
RESULTADO ESPERADO		
200 {token}; payload con usuarioId, rolNombre y exp; el paso 4 responde 200; el paso 5 responde 401 {"error":"Credenciales inválidas"}. Latencia <300 ms (este endpoint no tiene delayMiddleware).		
CRITERIO DE ACEPTACIÓN		
1) Sesión iniciada sin errores. 2) JWT firmado (HS256); si el ERS exige exp ≤15 min, registrar discrepancia. 3) Latencia <300 ms. 4) La contraseña no aparece en logs ni en claro en BD (si aparece en claro → hallazgo H-01).		
DATOS DE PRUEBA		
POST http://localhost:4444/autenticacion/login Body: {"nombre_usuario": "medico", "password": "medico"} También: admin/admin y paciente/paciente (dump-cuidarteplus.sql:288-290).		
TIPO DE PRUEBA		
Funcional y de seguridad (autenticación)		

ID	NOMBRE	REQUERIMIENTO
CP-02	Sesión: expiración y refresh token	RF-1.2, NFR-SEG-9
DESCRIPCIÓN		
Verificar que exista un mecanismo de renovación de sesión (refresh token) y que el access token vencido sea rechazado con 401.		
PRECONDICIONES		
Sesión iniciada (CP-01); vida útil del access token conocida (expiresIn: "2h" en auth.js:54).		
PASOS		
1) Ejecutar GET /examenes con token expirado o falsificado. 2) Intentar POST /autenticacion/refresh. 3) Revisar si existe cookie HttpOnly de refresh. 4) Revisar localStorage del navegador (AuthContext).		
RESULTADO ESPERADO		
Token vencido ⇒ 401; refresh ⇒ nuevo access token; refresh en cookie HttpOnly; Secure; SameSite=Strict.		

CRITERIO DE ACEPTACIÓN
1) El token vencido jamás autoriza. 2) Existe mecanismo de refresh (si no existe → incumplimiento RF-1.2, hallazgo H-09). 3) El token no debería vivir en localStorage.
DATOS DE PRUEBA
GET /examenes con token vencido. POST /autenticacion/refresh (endpoint requerido por RF-1.2). Inspección de Application/Storage del navegador.
TIPO DE PRUEBA
Funcional y de seguridad (gestión de sesión)

ID	NOMBRE	REQUERIMIENTO
CP-03	Política de contraseñas (≥12, 4 clases)	NFR-SEG-2, RF-1.1
DESCRIPCIÓN		
Verificar el rechazo de claves débiles en el registro y el cumplimiento de la política ≥12 caracteres con 4 clases de caracteres, más el almacenamiento con hash en BD.		
PRECONDICIONES		
API y BD operativas; endpoint POST /autenticacion/registro accesible.		
PASOS		
1) Enviar cada clave débil directo a la API (saltarse UI). 2) Enviar clave válida. 3) Verificar en BD el almacenamiento resultante (SELECT contrasena FROM usuarios).		
RESULTADO ESPERADO		
Claves <12 o sin combinación ⇒ 400 con mensaje de política; clave válida ⇒ 201; en BD solo hash bcrypt (nunca texto plano).		
CRITERIO DE ACEPTACIÓN		
1) Validación server-side (si solo existe en UI ⇒ fallo). 2) Si la política real del código es min(6) ⇒ discrepancia ERS (hallazgo H-01). 3) Ninguna clave en texto plano en BD.		
DATOS DE PRUEBA		
POST /autenticacion/registro con: hola123; Cort@12345; abcdefghijkl; Cuidarte2026!# (válida). También PUT /usuarios/:id con contrasena_hash.		
TIPO DE PRUEBA		
De seguridad (validación de credenciales) con enfoque funcional negativo		

ID	NOMBRE	REQUERIMIENTO
CP-04	Registro de examen médico con adjunto PDF	RF-3.1, RF-4.3, RF-4.4, RB-3
DESCRIPCIÓN		
Verificar que un médico registre un examen y adjunte un PDF asociado al paciente correcto, con auditoría y descarga íntegra.		
PRECONDICIONES		
Token rol medico; paciente ID existente en pacientes; archivo examen_sangre.pdf (fixture ~1.5 MB).		
PASOS		

1) UI: ficha paciente ⇒ Registrar Nuevo Examen ⇒ guardar. 2) Adjuntar PDF (o POST /documentos por Postman). 3) Cronometrar la operación total. 4) Verificar examen_medico, documentos_examen y auditoría con psql. 5) Descargar con GET /documentos/:id.
RESULTADO ESPERADO
201 en ambos POST; fila en examen_medico; BYTEA + nombre_archivo en documentos_examen; log EXAMENES_CREAR/DOCUMENTOS_CREAR; descarga 200 con Content-Disposition; total <10 s.
CRITERIO DE ACEPTACIÓN
1) 201 Created. 2) Total <10 s (ojo: POST /examenes y POST /documentos tienen delayMiddleware(5000) ⇒ medir y reportar H-13). 3) El examen solo es visible desde la ficha del paciente asignado. 4) Log antes de responder.
DATOS DE PRUEBA
POST /examenes body: {"tipo_examen_medico_id": 1, "paciente_id": 1, "diagnosis": "...", ...} POST /documentos multipart: campo documento + examen_medico_id + paciente_id.
TIPO DE PRUEBA
Funcional y de integración (extremo a extremo, con medición de rendimiento)

ID	NOMBRE	REQUERIMIENTO
CP-05	CRUD de pacientes por rol autorizado	RF-2.1 a RF-2.7, Ley 19.628
DESCRIPCIÓN		
Verificar que solo Médico/Admin creen y editen pacientes, con validación de RUT módulo 11 en backend y denegación a rol paciente.		
PRECONDICIONES		
Tokens de medico y paciente; BD operativa.		
PASOS		
1) Como medico: crear paciente RUT válido. 2) RUT inválido ⇒ ¿400? 3) Editar teléfono. 4) Como paciente: intentar POST /pacientes. 5) Como paciente: GET /pacientes/:id de otro ⇒ 403.		
RESULTADO ESPERADO		
1) 201; 2) 400; 3) 200; 4) 403; 5) 403.		
CRITERIO DE ACEPTACIÓN		
1) Validación de RUT módulo 11 en backend. 2) Ningún dato de terceros en respuestas a paciente. 3) Toda mutación genera auditoría (PACIENTES_*).		
DATOS DE PRUEBA		
POST /pacientes con RUT válido 12.345.678-9 e inválido 12.345.678-0. PUT /pacientes/:id GET /pacientes/:id		
TIPO DE PRUEBA		
Funcional y de integración, con control de acceso por rol		

ID	NOMBRE	REQUERIMIENTO
CP-06	RBAC: paciente solo ve sus propios exámenes y documentos	RF-4.1, RF-4.2, RB-1, NFR-SEG-4, Ley 20.584

DESCRIPCIÓN
Verificar que el rol paciente descargue solo lo suyo y sea bloqueado (403) hacia pacientes, exámenes y documentos ajenos.
PRECONDICIONES
Token rol paciente; existen examen propio y de otro paciente; IDs de documento propio y ajeno.
PASOS
1) Login paciente. 2) GET /examenes ⇒ solo suyos (filtro examenes.js:144-162). 3) GET /examenes/paciente/:id_ajeno ⇒ 403 "Solo puede ver sus propios exámenes". 4) GET /documentos/:id_ajeno ⇒ 403. 5) Repetir sin Authorization ⇒ 401.
RESULTADO ESPERADO
Paso 2: solo registros propios; pasos 3-4: 403 {"error":"No autorizado"}; paso 5: 401. Cero datos clínicos de terceros en el body.
CRITERIO DE ACEPTACIÓN
1) Cero fuga inter-paciente (Ley 20.584). 2) Denegación en backend (manipular URL no basta). 3) Los intentos denegados quedan auditables.
DATOS DE PRUEBA
GET /examenes (lista filtrada) GET /examenes/paciente/:id_ajeno GET /documentos/examen/:examen_ajeno_id GET /examenes sin Authorization
TIPO DE PRUEBA
De seguridad: control de acceso basado en roles (RBAC)

ID	NOMBRE	REQUERIMIENTO
CP-07	RBAC: paciente no muta exámenes ni escala privilegios	RB-2, RB-3, RF-3.1, NFR-SEG-4
DESCRIPCIÓN		
Verificar que el rol paciente no cree/edite/borre exámenes ni usuarios, no se auto-promueva a admin ni altere usuario_id de su ficha clínica.		
PRECONDICIONES		
Token de paciente (y de medico para la prueba de escalada de rol); BD con datos sintéticos.		
PASOS		
1) Enviar cada mutación con JWT de paciente. 2) Verificar BD tras cada intento. 3) Intento de auto-promoción vía PUT /usuarios/:id con rol_id de admin (como medico).		
RESULTADO ESPERADO		
Todo ⇒ 403; BD intacta; usuario_id sin cambios; el médico no puede cambiar su rol_id a admin.		
CRITERIO DE ACEPTACIÓN		
1) Rol evaluado en backend. 2) Si POST /usuarios devuelve 201 ⇒ H-02; si PUT /pacientes cambia usuario_id ⇒ H-10; si el médico puede cambiar rol_id ⇒ H-11. 3) Cobertura de la matriz RBAC para el rol paciente.		
DATOS DE PRUEBA		
Con token paciente: POST /examenes; PUT /examenes/:id; DELETE /examenes/:id; POST /usuarios con rol_id de admin; PUT /pacientes/:id cambiando usuario_id; DELETE /usuarios/:id. Con token medico: PUT /usuarios/2 con rol_id 1.		

TIPO DE PRUEBA
De seguridad: control de acceso y escalada de privilegios

ID	NOMBRE	REQUERIMIENTO
CP-08	Eliminación de examen: soft delete + auditoría	RF-3.3, RF-5.1, Ley 19.628
DESCRIPCIÓN		
Confirmar el borrado lógico (soft delete) previo a un modal de confirmación y el registro completo del evento en la tabla auditoría.		
PRECONDICIONES		
Token rol admin o medico; examen existente; acceso psql a la BD de QA.		
PASOS		
1) UI: ficha ⇒ Eliminar Examen. 2) Verificar modal de confirmación. 3) Confirmar. 4) Verificar desaparición en UI. 5) psql: SELECT id, eliminado FROM examen_medico WHERE id=…; SELECT * FROM auditoria WHERE accion LIKE '%…%'. 6) Cancelar el modal en otro examen ⇒ nada cambia.		
RESULTADO ESPERADO		
Fila actualizada eliminado=true (sin DELETE FROM); log con usuario, acción=ELIMINACION_LOGICA_EXAMEN, recurso_id, timestamp UTC e ip_origen; el GET tras DELETE sigue accesible con eliminado=true.		
CRITERIO DE ACEPTACIÓN		
1) Si el código usa DELETE FROM examen_medico (examenes.js:408) ⇒ RECHAZADO, hallazgo H-06. 2) Si el esquema auditoria no tiene recurso_id ni ip_origen (init.sql:88-93) ⇒ H-12. 3) Modal presente en UI. 4) Log antes del 200.		
DATOS DE PRUEBA		
DELETE /examenes/:id con admin. GET /examenes/:id tras el DELETE (soft delete). SQL: SELECT id, eliminado FROM examen_medico WHERE id=…; SELECT * FROM auditoria WHERE accion LIKE '%…%';		
TIPO DE PRUEBA		
De integridad y auditoría		

ID	NOMBRE	REQUERIMIENTO
CP-09	Inmutabilidad de la tabla auditoría	RF-5.1, NFR-SEG-7, Ley 19.628
DESCRIPCIÓN		
Verificar que ni la aplicación ni un usuario Admin puedan modificar o borrar registros de la bitácora de auditoría.		
PRECONDICIONES		
Acceso psql con credenciales de la aplicación; registro existente en auditoria.		
PASOS		

1) Identificar un registro existente. 2) Ejecutar UPDATE/DELETE con credenciales de la app. 3) Releer el registro. 4) Verificar REVOKE en information_schema. 5) Borrar un usuario (DELETE /usuarios/:id) y verificar si sus logs quedan con usuario_id NULL.
RESULTADO ESPERADO
Ambas sentencias denegadas (permission denied); registro idéntico tras el intento; la trazabilidad del autor se conserva al borrar usuarios.
CRITERIO DE ACEPTACIÓN
1) append-only real (si no hay REVOKE ⇒ H-12). 2) Si la FK usa ON DELETE SET NULL y anula la atribución ⇒ H-07. 3) REVOKE documentado en el DDL.
DATOS DE PRUEBA
UPDATE auditoria SET accion='HACK' WHERE id=1; DELETE FROM auditoria WHERE id=1; SELECT * FROM information_schema.role_table_grants WHERE table_name='auditoria';
TIPO DE PRUEBA
De integridad y auditoría (inmutabilidad del registro)

ID	NOMBRE	REQUERIMIENTO
CP-10	Inyección SQL en login	NFR-SEG-2, NFR-SEG-5, OWASP A03
DESCRIPCIÓN		
Verificar que las cadenas maliciosas en el login se traten como literales (consultas parametrizadas $1) y no alteren la BD.		
PRECONDICIONES		
API operativa; tabla usuarios con datos del dump.		
PASOS		
1) Enviar payloads por Postman. 2) Active scan de ZAP sobre /autenticacion. 3) Revisar respuestas y logs. 4) Verificar integridad de usuarios (SELECT count(*)).		
RESULTADO ESPERADO		
401 {"error":"Credenciales inválidas"} ante todos los payloads; cero 500; sin mensajes de PostgreSQL; tabla intacta.		
CRITERIO DE ACEPTACIÓN		
1) 401 uniforme. 2) Sin stack traces (si glosa trae err.message ⇒ H-15). 3) ZAP sin SQLi ≥media. 4) DROP no ejecutado. El código usa $1 ⇒ se espera PASS.		
DATOS DE PRUEBA		
POST /autenticacion/login con payloads: {"nombre_usuario":"' OR '1'='1", "password":"' OR '1'='1"} admin'-- '; DROP TABLE usuarios;--		
TIPO DE PRUEBA		
De seguridad dinámica (DAST): inyección SQL		

ID	NOMBRE	REQUERIMIENTO

CP-11	XSS en campos clínicos	NFR-SEG-5, OWASP A03
DESCRIPCIÓN		
Verificar que payloads XSS en campos clínicos (diagnosis, observaciones, notas) se almacenen como texto literal y no se ejecuten, con cabecera CSP presente.		
PRECONDICIONES		
Token rol medico; navegador para inspección.		
PASOS		
1) Crear registros con payload (rol medico). 2) Abrir la ficha en el navegador. 3) ¿Se dispara alert? 4) Revisar el JSON crudo y la cabecera CSP.		
RESULTADO ESPERADO		
Payload como texto literal; sin ejecución de JS; cabecera Content-Security-Policy presente.		
CRITERIO DE ACEPTACIÓN		
1) Cero ejecución de JS (React escapa por defecto ⇒ probable PASS en UI). 2) Sin cabecera CSP ⇒ H-14. 3) Backend también escapa/rechaza (defensa en profundidad).		
DATOS DE PRUEBA		
POST /examenes con "diagnosis": "<script>alert('XSS')</script>" POST /pacientes con "observaciones_medicas_generales": "<img src=x onerror=alert(1)>"		
TIPO DE PRUEBA		
De seguridad dinámica (DAST): scripting entre sitios (XSS)		

ID	NOMBRE	REQUERIMIENTO
CP-12	TLS y cabeceras de seguridad	NFR-SEG-1, OWASP A05
DESCRIPCIÓN		
Verificar cifrado en tránsito (TLS 1.2+), redirect HTTP→HTTPS, cabeceras de seguridad mínimas y CORS restringido a una allowlist.		
PRECONDICIONES		
Entorno QA accesible por HTTP y (si aplica) HTTPS; herramienta curl.		
PASOS		
1) HTTP ⇒ redirect 301. 2) HTTPS ⇒ TLS ≥1.2. 3) Inspeccionar Strict-Transport-Security, X-Content-Type-Options, X-Frame-Options, Content-Security-Policy y Referrer-Policy. 4) Revisar CORS con Origin: https://evil.example.		
RESULTADO ESPERADO		
Redirect; TLS 1.2/1.3; todas las cabeceras presentes; CORS solo con orígenes de la allowlist.		
CRITERIO DE ACEPTACIÓN		
1) Sin HTTP aceptado sin redireccionar. 2) 100% de cabeceras (si están ausentes ⇒ H-14; si cors() es abierto ⇒ H-14). 3) TLS <1.2 deshabilitado.		
DATOS DE PRUEBA		
curl -I http://localhost:4444/examenes curl -I https://<qa>/examenes SSL Labs GET / y GET /openapi.json		
TIPO DE PRUEBA		

De seguridad: configuración, cifrado en tránsito y cabeceras

ID	NOMBRE	REQUERIMIENTO
CP-13	Carga concurrente de 200 usuarios	NFR-PERF-1, NFR-PERF-3
DESCRIPCIÓN		
Medir la latencia y estabilidad de la API con 200 hilos concurrentes y cuantificar el impacto de delayMiddleware(5000) mediante una prueba A/B.		
PRECONDICIONES		
QA Docker aislado; plan Cuidarte_LoadTest_200.jmx; tokens pregenerados.		
PASOS		
1) JMeter ⇒ cargar el plan. 2) Corrida A: GET /examenes (con delay 5 s). 3) Corrida B: endpoint sin delay (GET /roles o GET /). 4) Aggregate Report + CPU/memoria.		
RESULTADO ESPERADO		
Promedio <300 ms; 0% error; CPU <80%.		
CRITERIO DE ACEPTACIÓN		
1) Corrida B <300 ms ⇒ base sana. 2) Corrida A ≥5000 ms ⇒ confirma H-13 e incumplimiento NFR-PERF-1/3. 3) Cero 500 y cero caídas. 4) Sin agotamiento del Pool de pg.		
DATOS DE PRUEBA		
200 hilos · ramp-up 10 s · 5 min. GET /examenes (con delay) GET /roles o GET / (sin delay) Authorization: Bearer.		
TIPO DE PRUEBA		
No funcional: rendimiento y carga		

ID	NOMBRE	REQUERIMIENTO
CP-14	Carga de SPA y transferencia de adjuntos	NFR-PERF-2, RF-4
DESCRIPCIÓN		
Medir el render inicial de la SPA (<2 s en red móvil) y la subida/descarga de adjuntos (≤10 s) con verificación de integridad byte a byte.		
PRECONDICIONES		
Frontend desplegado (:3333); archivo PDF de prueba; throttle Slow 4G en DevTools.		
PASOS		
1) Lighthouse ×3 corridas en red móvil. 2) Cronometrar la subida desde UI. 3) Cronometrar la descarga. 4) Comparar hash MD5 del archivo subido vs descargado.		
RESULTADO ESPERADO		
Carga <2 s promedio; transferencias ≤10 s; hash idéntico.		
CRITERIO DE ACEPTACIÓN		
1) Promedio de Lighthouse <2 s. 2) Transferencias ≤10 s (la subida tiene delay 5 s ⇒ medir). 3) Integridad byte a byte. 4) Verificar que uploads/ sea un volumen persistente en Docker.		
DATOS DE PRUEBA		

URL raíz del frontend (:3333) con throttle Slow 4G. POST /documentos (PDF 1.5 MB) GET /documentos/:id MD5 del archivo subido vs descargado.
TIPO DE PRUEBA
No funcional: rendimiento de la interfaz y de las transferencias

ID	NOMBRE	REQUERIMIENTO
CP-15	Accesibilidad y UAT con adultos mayores	NFR-USAB-1, NFR-USAB-4, RF-4.1
DESCRIPCIÓN		
Verificar que 5 adultos mayores (>65) completen el flujo login → paciente → exámenes → descargar PDF sin ayuda, y que la UI cumpla WCAG 2.1 AA.		
PRECONDICIONES		
Credenciales sintéticas; módulos Login, PacientesList y MisResultados; Axe DevTools; tablet y laptop; panel de 5 evaluadores.		
PASOS		
1) Axe en /login, lista de pacientes y MisResultados. 2) Cada evaluador inicia sesión. 3) Busca paciente/examen. 4) Descarga PDF. 5) Registrar tiempos/dudas; probar solo teclado (Tab/Enter/Esc).		
RESULTADO ESPERADO		
0 violaciones críticas en Axe; 5/5 completan; texto >12 px; contraste ≥4.5:1; targets ≥48 px.		
CRITERIO DE ACEPTACIÓN		
1) 5/5 sin asistencia. 2) Score de Axe ≥90% sin críticas. 3) Flujo 100% por teclado (RoleGuard no debe romper la navegación). 4) Video por evaluador.		
DATOS DE PRUEBA		
Credenciales sintéticas del dump. Axe DevTools en /login, lista de pacientes y MisResultados. Tablet + laptop; flujo completo de descarga de PDF.		
TIPO DE PRUEBA		
No funcional: usabilidad y accesibilidad (aceptación de usuario)		

ID	NOMBRE	REQUERIMIENTO
CP-16	Compatibilidad de navegadores y dispositivos	NFR-COMPAT-1, NFR-COMPAT-2
DESCRIPCIÓN		
Ejecutar un flujo reducido (login ⇒ lista ⇒ descarga) en 4 navegadores × 3 dispositivos (12 combinaciones) y verificar responsividad y consola limpia.		
PRECONDICIONES		
Frontend desplegado; Chrome, Firefox, Safari y Edge (2 últimas versiones) en escritorio, tablet y móvil.		
PASOS		
1) Ejecutar el flujo por cada combinación (12). 2) Verificar responsividad (Tailwind) y modales. 3) Consola del navegador sin errores JS.		

RESULTADO ESPERADO
100% de combinaciones operativas.
CRITERIO DE ACEPTACIÓN
1) Cero bloqueos. 2) Sin scroll horizontal no intencional. 3) Consola limpia.
DATOS DE PRUEBA
Chrome, Firefox, Safari, Edge × escritorio/tablet/móvil. Flujo: login ⇒ lista de pacientes ⇒ descarga de PDF.
TIPO DE PRUEBA
No funcional: compatibilidad

ID	NOMBRE	REQUERIMIENTO
CP-17	Disponibilidad 99.5% y restauración de respaldos	NFR-DIS-1, NFR-DIS-2, NFR-SEG-7
DESCRIPCIÓN		
Verificar el uptime mensual ≥99.5% mediante healthcheck monitoreado y la restaurabilidad de BD y uploads sin pérdida de datos.		
PRECONDICIONES		
Entorno QA desplegado; dump dump-cuidarteplus.sql; volumen de BACKEND/uploads/; acceso de monitoreo.		
PASOS		
1) Extraer el histórico de monitoreo (GET / cada 60 s por 30 días). 2) Calcular uptime. 3) Restaurar dump en BD descartable. 4) Verificar conteos (usuarios, pacientes, examen_medico, documentos_examen). 5) Verificar que uploads/ sobrevive restart de Docker (volumen).		
RESULTADO ESPERADO		
Uptime ≥99.5% (máx. ~3 h 39 min caído/mes); restauración sin pérdida; uploads persistentes.		
CRITERIO DE ACEPTACIÓN		
1) ≥99.5%. 2) Checksums/conteos idénticos. 3) Si uploads/ se pierde al redesplegar ⇒ riesgo confirmado. 4) Runbook de rollback documentado.		
DATOS DE PRUEBA		
GET / (healthcheck {"name":"cuidarteplus","status":"ok"}) monitoreado cada 60 s por 30 días. dump-cuidarteplus.sql Volumen BACKEND/uploads/.		
TIPO DE PRUEBA		
No funcional: disponibilidad y recuperación ante fallas		

ID	NOMBRE	REQUERIMIENTO
CP-18	Autenticación obligatoria en endpoints mutantes	NFR-SEG-4, RB-2
DESCRIPCIÓN		
Verificar que toda operación de mutación exija JWT y rol adecuado según la matriz RBAC, sin token ⇒ 401 y con rol insuficiente ⇒ 403.		
PRECONDICIONES		
Colección/curl sin header Authorization; tokens de paciente y medico; BD con datos sintéticos.		
PASOS		

1) Enviar cada petición con curl sin token. 2) Con token de paciente: POST /usuarios con rol_id admin. 3) Con token de medico: PUT /usuarios/:id cambiando su rol_id a admin. 4) Verificar BD después de cada intento.
RESULTADO ESPERADO
Todo ⇒ 401 sin token / 403 con rol insuficiente; cero cambios en BD.
CRITERIO DE ACEPTACIÓN
1) DELETE /usuarios sin token debe dar 401 (si ejecuta el borrado ⇒ H-03 CRÍTICO). 2) Mutaciones en /roles sin token ⇒ 401 (si responde 200/201 ⇒ H-04). 3) Búsqueda RUT sin token ⇒ 401 (si devuelve ficha completa ⇒ H-05). 4) POST /usuarios con paciente ⇒ 403 (si responde 201 ⇒ H-02). 5) Auto-promoción del médico ⇒ 403 (si es posible ⇒ H-11).
DATOS DE PRUEBA
Sin Authorization: DELETE /usuarios/999999 DELETE /roles/999999 POST /roles {"nombre":"hacker"} PUT /roles/1 GET /usuarios GET /auditoria GET /pacientes/buscar/rut/11111111-1 Con token paciente: POST /usuarios con rol_id 1. Con token medico: PUT /usuarios/2 con rol_id 1.
TIPO DE PRUEBA
De seguridad: control de acceso en endpoints de mutación

ID	NOMBRE	REQUERIMIENTO
CP-19	Exposición de información y configuración	NFR-SEG-1, NFR-SEG-5
DESCRIPCIÓN		
Cuantificar qué información expone la API sin autenticación (Swagger, endpoints públicos) y en las respuestas de error 500 (glosa del cliente), además de secretos en el paquete.		
PRECONDICIONES		
API accesible; ZIP del código fuente para revisar archivos .env.		
PASOS		
1) Catalogar endpoints públicos vía /openapi.json. 2) Enviar body inválido ⇒ leer detalles. 3) GET /examenes/abc (cast a BIGINT) ⇒ leer glosa. 4) Revisar .env presentes en el ZIP entregado.		
RESULTADO ESPERADO		
Swagger puede ser público en QA; errores 500 genéricos; cero secretos en el paquete entregado.		
CRITERIO DE ACEPTACIÓN		
1) Si glosa trae err.message de PostgreSQL ⇒ H-15. 2) Endpoints públicos coherentes con la matriz RBAC (/roles GET aceptable, mutaciones no). 3) Si hay .env con JWT_SECRET y password de BD en el ZIP ⇒ H-08.		
DATOS DE PRUEBA		

GET /, GET /openapi.json, GET /docs POST /pacientes con campo faltante GET /examenes/abc (id no numérico) Listado de archivos .env del ZIP.
TIPO DE PRUEBA
De seguridad: exposición de información y configuración

Cuando el comportamiento real del software difiere del criterio de aceptación, el caso se considera rechazado y queda asociado a un hallazgo (H-01 a H-17). El Anexo B reúne el catálogo completo de hallazgos y el Anexo C, la evidencia de la ejecución automatizada.

Anexos

Los anexos complementan las secciones 1 a 4 con la evidencia que sustenta el plan: la trazabilidad completa entre la especificación y los casos diseñados (Anexo A), el catálogo de hallazgos detectados en el código fuente (Anexo B) y el resultado de la ejecución automatizada de la colección de pruebas (Anexo C).

Anexo A. Matriz de trazabilidad ERS - casos de prueba

Cada requerimiento de la especificación (ERS v1.1) se asocia al menos a un caso de prueba y cada caso responde al menos a un requerimiento: no hay identificadores huérfanos ni casos sin origen. La cobertura es de 11 RF + 14 NFR + 3 RB = 28 de 28 identificadores (100%), distribuidos en los 19 casos diseñados en la sección 4.

ID requerimiento ERS	Tipo	Tipo de prueba	Control normativo	Caso(s)
RF-1.1 (Login)	Funcional	Funcional + seguridad	NFR-SEG-2/9, hash de contraseña	CP-01, CP-03, CP-10
RF-1.2 (Refresh token)	Funcional	Funcional + seguridad	NFR-SEG-9	CP-02
RF-2.1 a RF-2.7 (Usuarios)	Funcional	Funcional / integración + RBAC	Ley N° 19.628	CP-05, CP-18
RF-3.1 / RF-3.2 (Exámenes)	Funcional	Funcional	Ley N° 20.584	CP-04, CP-07
RF-3.3 (Soft delete)	Funcional	Integridad / auditoría	Borrado lógico + modal	CP-08
RF-4.1 / RF-4.2 (Acceso del paciente)	Funcional	Funcional / RBAC	Ley N° 20.584	CP-06, CP-15
RF-4.3 / RF-4.4 (Adjuntos)	Funcional	Funcional / almacenamiento	Adjuntos PDF e imagen	CP-04, CP-14
RF-5.1 (Auditoría)	Funcional	Auditoría e integridad	Log inmutable con IP	CP-08, CP-09
NFR-SEG-1 (TLS y cabeceras)	No funcional	Seguridad DAST	TLS 1.2+, OWASP A05	CP-12, CP-19
NFR-SEG-2 (Contraseñas)	No funcional	Seguridad + funcional	OWASP A07	CP-01, CP-03, CP-10
NFR-SEG-3 (Cifrado en reposo)	No funcional	Seguridad / infraestructura	Datos sensibles en reposo	CP-14, CP-17
NFR-SEG-4 (RBAC)	No funcional	Seguridad / RBAC	Ley N° 20.584, RB-1/2/3	CP-06, CP-07, CP-18
NFR-SEG-5 (SQLi, XSS y errores)	No funcional	Seguridad DAST / SAST	OWASP A03	CP-10, CP-11, CP-12
NFR-SEG-7 (Respaldos)	No funcional	Disponibilidad / operación	Backups restaurables	CP-17
NFR-SEG-9 (Sesión JWT)	No funcional	Seguridad	OWASP A07	CP-01, CP-02
NFR-PERF-1 (< 300 ms)	No funcional	Rendimiento	Latencia de la API	CP-13
NFR-PERF-2 (SPA < 2 s)	No funcional	Rendimiento	Lighthouse en red móvil	CP-14
NFR-PERF-3 (200 usuarios)	No funcional	Rendimiento / carga	Concurrencia	CP-13
NFR-USAB-1 / NFR-USAB-4	No funcional	Usabilidad / accesibilidad	WCAG 2.1 AA	CP-15

ID requerimiento ERS	Tipo	Tipo de prueba	Control normativo	Caso(s)
NFR-COMPAT-1 / NFR-COMPAT-2	No funcional	Compatibilidad	Navegadores y dispositivos	CP-16
NFR-DIS-1 / NFR-DIS-2	No funcional	Disponibilidad	Uptime 99,5% y rollback	CP-17
RB-1 (Reserva clínica)	Regla de negocio	Control de acceso	Ley N° 20.584	CP-06
RB-2 (Segregación de roles)	Regla de negocio	Control de acceso	Ley N° 19.628	CP-07, CP-18
RB-3 (Profesional tratante)	Regla de negocio	Control de acceso	Ley N° 20.584	CP-04, CP-07

Tabla A.1. Trazabilidad ERS - casos de prueba. Cobertura 28/28 (100%).

Anexo B. Catálogo de hallazgos de seguridad

Hallazgos obtenidos mediante revisión estática del código fuente y contrastados con el ERS v1.1, OWASP Top 10 (2021) y las Leyes N° 19.628 y N° 20.584. Distribución por severidad: 6 críticos (H-01 a H-06), 6 altos (H-07 a H-12) y 5 medios (H-13 a H-17); 17 en total. La columna de ubicación referencia archivo y línea dentro de CodigoFuenteB/BACKEND, de modo que cada hallazgo es verificable directamente sobre el código entregado.

ID	Hallazgo	Severidad	OWASP	Ubicación (archivo:línea)	Lo detecta
H-01	Contraseñas almacenadas y comparadas en texto plano	Crítica	A07	auth.js:21 y auth.js:110	CP-01, CP-03
H-02	POST /usuarios acepta rol_id arbitrario con cualquier token	Crítica	A01	users.js:23-53	CP-07, CP-18
H-03	DELETE /usuarios/:id ejecuta el borrado antes de leer el token	Crítica	A01	users.js:571-589	CP-18
H-04	La API /roles no exige autenticación en POST, PUT ni DELETE	Crítica	A01	roles.js:18, 36, 46, 57, 76	CP-18
H-05	La búsqueda pública por RUT expone la ficha clínica completa	Crítica	A01	pacientes.js:249-273	CP-06, CP-19
H-06	Eliminación física de registros: no existe borrado lógico	Crítica	A04	examenes.js:408; pacientes.js:399; users.js:574; documentos.js:275	CP-08
H-07	Borrar un usuario anula la autoría de sus registros de auditoría	Alta	A04	sql/init.sql:90	CP-09
H-08	Secretos versionados y fallback de JWT_SECRET a la cadena 'inseguro'	Alta	A02	BACKEND/.env:1-3; auth.js:8	CP-01, CP-12
H-09	Sin refresh token; JWT de 2 h almacenado en localStorage	Alta	A07	auth.js:54; AuthContext.jsx:41; api.jsx:21	CP-02
H-10	El paciente puede reasignar el usuario_id de su propia ficha	Alta	A01	pacientes.js:341, 344-350	CP-07
H-11	El rol Médico puede promoverse a Administrador	Alta	A01	users.js:484, 522-532	CP-07, CP-18
H-12	Auditoría sin IP ni recurso, no atómica y con tipos incorrectos	Alta	A09	sql/init.sql:88-93; roles.js:24-27; users.js:581-587	CP-08, CP-09
H-13	Latencia artificial de 5 s en endpoints críticos	Media	-	middleware/delay.js:5-10, aplicado en examenes.js:46, 99, 330; pacientes.js:145; documentos.js:66	CP-04, CP-13, CP-14
H-14	Sin cabeceras de seguridad (helmet, CSP, HSTS) y CORS abierto	Media	A05	app.js:21	CP-11, CP-12
H-15	Los errores internos de PostgreSQL se devuelven al cliente	Media	A05	auth.js:67; examenes.js:94; documentos.js:115	CP-10, CP-19
H-16	Sin limite de intentos de inicio de sesión (fuerza bruta)	Media	A07	auth.js:10	CP-01, CP-10
H-17	Adjuntos con MIME declarado por el cliente, nombre sin sanitizar y BYTEA sin cifrar	Media	A04	documentos.js:10-28 y 248-251; sql/init.sql:82	CP-04, CP-14

Tabla B.1. Catálogo de los 17 hallazgos y su ubicación en el código fuente.

Controles verificados como correctos: todas las consultas SQL usan parámetros posicionales de pg ($1), por lo que no se detectaron vulnerabilidades de inyección SQL (OWASP A03); el control de acceso de lectura clínica del rol paciente (examenes.js:277-289 y documentos.js:222-234) verifica correctamente la propiedad del registro; y la validación de entrada esta centralizada mediante esquemas yup y el middleware validate.js.

Anexo C. Evidencia de ejecución automatizada

La colección Cuidarte_CP01-19.postman_collection.json se ejecutó con Newman 6 contra el entorno QA en Docker (backend en http://localhost:4444 y PostgreSQL, levantados desde el docker-compose.yml del código fuente), sin modificar una sola línea de la aplicación. La evidencia bruta queda registrada en reports/results.json.

Métrica de la corrida	Valor
Requests ejecutados	48
Fallos de transporte	0
Aserciones ejecutadas	66
Aserciones fallidas (incumplimientos del ERS)	22
Duración total	55,2 s
Latencia media / mínima / máxima	947 ms / 3 ms / 5.016 ms
Evidencia bruta	reports/results.json

Tabla C.1. Resumen de la corrida del 22 de septiembre de 2026.

Una aserción fallida no indica una prueba mal construida: indica que el comportamiento real del software difiere del comportamiento exigido por el ERS. Las 22 fallas son, por lo tanto, hallazgos confirmados en tiempo de ejecución y no defectos del plan de pruebas.

#	Caso y aserción	Esperado (ERS)	Obtenido	Hallazgo
1	CP-01 - vigencia (exp) del JWT	<= 15 min	120 min	H-09
2	CP-02 - POST /autenticacion/refresh	200 o 201	404: el endpoint no existe	H-09
3	CP-03 - registro con clave de 6 caracteres	400 por política >= 12	201 creado	H-01
4	CP-04 - latencia de POST /examenes	< 300 ms	5.014 ms	H-13
5	CP-04 - latencia de POST /documentos	< 300 ms	5.016 ms	H-13
6	CP-07 - un paciente crea un usuario administrador	403	201 creado	H-02 (crítico)
7	CP-07 - un médico cambia su propio rol_id	400 o 403	200 con rol admin	H-11 (alto)
8	CP-08 - borrado lógico: GET tras DELETE	200 con eliminado = true	404: el registro se destruyó	H-06 (crítico)
9	CP-08 - auditoría con ip_origen y recurso_id	ambos campos presentes	ambos ausentes en el esquema	H-12 (alto)
10	CP-18 - DELETE /usuarios sin token	401	404: ejecuta el borrado	H-03 (crítico)
11	CP-18 - DELETE /roles sin token	401	404	H-04 (crítico)
12	CP-18 - POST /roles sin token	401	500 (en la 1.ª corrida: 201)	H-04 (crítico)
13	CP-18 y CP-19 - búsqueda por RUT sin token	401	200 con la ficha completa	H-05 (crítico)
14	CP-18 - PUT /roles/:id sin token	401	200	H-04 (crítico)
15	CP-12 - cabecera X-Content-Type-Options	nosniff	ausente	H-14
16	CP-12 - cabecera X-Frame-Options	presente	ausente	H-14
17	CP-12 - cabecera Content-Security-Policy	presente	ausente	H-14
18	CP-12 - cabecera Strict-Transport-Security	presente	ausente	H-14
19	CP-12 - política CORS	origen restringido	Access-Control-Allow-Origin: *	H-14

#	Caso y aserción	Esperado (ERS)	Obtenido	Hallazgo
20	CP-19 - glosa del error 500	mensaje genérico	invalid input syntax for type bigint	H-15
21	CP-11 - CSP en la respuesta con payload XSS	presente	ausente	H-14
22	CP-13A - GET /examenes	< 300 ms	5.009 ms	H-13

Tabla C.2. Las 22 aserciones fallidas y su correlación con los hallazgos.

En sentido inverso, la misma corrida confirma los controles que si cumplen el ERS. Estos resultados sostienen el veredicto del informe: el problema del sistema no es la ausencia total de controles, sino su aplicación incompleta e inconsistente.

Caso	Comportamiento conforme verificado en ejecución
CP-01	Login 200; credencial incorrecta 401; payloads SQLi y DROP TABLE rechazados con 401 y sin error de base de datos.
CP-04	Examen 201, documento 201 y descarga 200 con Content-Disposition: attachment.
CP-05	CRUD de pacientes: 201 con RUT valido, 400 con RUT invalido y 403 para el rol paciente.
CP-06	El paciente solo obtiene sus propios exámenes; ficha y documentos ajenos responden 403.
CP-07	Creación y edición de exámenes por el rol paciente: 403 en ambos intentos.
CP-09	GET /auditoria con rol paciente: 403.
CP-10	Inyección SQL clasica en el login: 401 uniforme, sin filtración del error de la base.
CP-11	Payload XSS almacenado y devuelto como texto, sin ejecución en el servidor.
CP-13B	Latencia de control en GET / por debajo de 300 ms.
CP-17	Healthcheck GET / responde status: ok.

Tabla C.3. Comportamientos conformes verificados en la misma corrida.

Reproducción: levantar los servicios cuidarteplus-postgres-ev y cuidarteplus-backend-ev con docker compose desde CodigoFuenteB/CodigoFuenteB/docker-compose.yml y ejecutar npm install y luego npm test en la raiz del paquete de evaluación.